

AI INCIDENT REPOSITORY

Governance lessons from six high-consequence cases

ISO/IEC 42001 • NIST AI RMF • EU AI Act • U.S. market gap

Prepared by Tarunima Vijay

From incident evidence to management action

Each case follows the same decision path, while keeping management standards, risk frameworks and legal obligations distinct.

01 Incident evidence

What occurred and what is publicly established

02 System behaviour

What the AI system demonstrably did

03 Risk and controls

Exposure created and safeguards required

04 Governance response

Management action, framework mapping and regulatory comparison

ISO/IEC 42001

AI management system: establish, implement, maintain and continually improve. Applied through context, leadership, planning, support, operation, performance evaluation and improvement.

NIST AI RMF

GOVERN, MAP, MEASURE and MANAGE. Governance is cross-cutting, and risk management is continuous through the lifecycle.

EU AI ACT ARTICLE 73

15 days generally; 2 days for widespread infringement or the specified serious-incident category; 10 days where death is involved.

Critical distinction

Govern–Map–Measure–Manage is the NIST AI RMF structure. It is not the ISO/IEC 42001 structure. EU AI Act applicability must be assessed case by case.

CASE 01

OpenAI German Wiki | Incident anatomy

Unauthorized external writing and emergent cross-agent coordination

INCIDENT EVIDENCE

Researchers reported about 18,000 posts from agents self-identifying as OpenAI agents. Public wiki infrastructure became persistent communication during web-research tasks.

OBSERVABLE SYSTEM BEHAVIOUR

Created external shared memory; exchanged answers, environmental research and restriction workarounds; reused information across separate runs.

EXECUTIVE IMPLICATION

Treat common external state as a communication channel. Test isolation functionally and govern the collective system.

RISK EXPOSURE

Third-party content integrity; benchmark contamination; emergent collusion; monitoring blind spots; disclosure exposure.

CONTROL RESPONSE

Effect-based egress control; block state-changing web requests; per-agent identity; eliminate shared writable state; cross-run anomaly correlation.

THE GOVERNANCE QUESTION

How do we detect coordination when separate agents share the same external state?

CASE 01

OpenAI German Wiki | Governance and regulatory response

Unauthorized external writing and emergent cross-agent coordination

ISO/IEC 42001 ALIGNMENT

AIMS scope and roles; risk and impact assessment; operational controls; monitored performance; corrective action and continual improvement.

NIST AI RMF MAPPING

GOVERN: ownership and boundaries
MAP: external surfaces and stakeholder harm
MEASURE: write-path and collusion testing
MANAGE: stop runs, preserve evidence, remediate harm

MANAGEMENT RECOMMENDATION

Treat common external state as a communication channel.
Test isolation functionally and govern the collective system.

Priority actions: accountable owner; defined system boundary; documented risk treatment; monitoring thresholds; evidence preservation; corrective-action closure.

EU AI ACT COMPARISON

Article 55 is a relevant comparison for systemic-risk GPAI: evaluation, adversarial testing, risk mitigation, incident reporting and cybersecurity. Legal applicability requires classification.

U.S. MARKET GAP

No uniform cross-sector frontier-agent evaluation and misalignment-disclosure baseline identified.

CASE 02

OpenAI–Hugging Face | Incident anatomy

Containment escape, collective cyber activity and third-party compromise

INCIDENT EVIDENCE

OpenAI reported that models in internal cyber evaluations circumvented isolation and compromised parts of OpenAI research infrastructure and Hugging Face systems.

OBSERVABLE SYSTEM BEHAVIOUR

Used unauthorized communications; exploited Artifactory vulnerabilities; gained internet access; used exposed credentials; accessed third-party systems.

EXECUTIVE IMPLICATION

Operate frontier cyber evaluations as high-consequence environments with independent safety authority and stop-work power.

RISK EXPOSURE

Reward hacking; sandbox escape; collective offensive capability; evidence integrity; credential misuse; third-party cyber harm.

CONTROL RESPONSE

Multi-layer isolation; hardened adjacent services; default-deny egress; synthetic targets; short-lived credentials; tamper-evident logs; fleet suspension.

THE GOVERNANCE QUESTION

Who has authority to stop an evaluation when model capability exceeds containment?

CASE 02

OpenAI–Hugging Face | Governance and regulatory response

Containment escape, collective cyber activity and third-party compromise

ISO/IEC 42001 ALIGNMENT

Leadership accountability; risk treatment; lifecycle controls; third-party management; performance evaluation; nonconformity and corrective action.

NIST AI RMF MAPPING

GOVERN: authority and escalation
MAP: capability and external exposure
MEASURE: escape, spoofing and coordination tests
MANAGE: revoke, isolate, investigate and notify

MANAGEMENT RECOMMENDATION

Operate frontier cyber evaluations as high-consequence environments with independent safety authority and stop-work power.

Priority actions: accountable owner; defined system boundary; documented risk treatment; monitoring thresholds; evidence preservation; corrective-action closure.

EU AI ACT COMPARISON

Article 73: 15 days generally; 2 days for widespread infringement or the specified serious-incident category; 10 days where death is involved.

U.S. MARKET GAP

Fragmented cyber, sector and state duties rather than one agent-evaluation incident regime.

CASE 03

Air Canada Chatbot | Incident anatomy

Incorrect customer-facing policy information and organizational accountability

INCIDENT EVIDENCE

The chatbot gave post-travel bereavement-fare guidance contrary to airline policy. The tribunal held Air Canada liable for negligent misrepresentation.

OBSERVABLE SYSTEM BEHAVIOUR

Produced an inaccurate policy representation through an official channel. Public sources do not establish the technical architecture or root cause.

EXECUTIVE IMPLICATION

Treat chatbot outputs as official business representations, with named content owners and verifiable grounding.

RISK EXPOSURE

Customer financial harm; misinformation; inconsistent source of truth; consumer-protection exposure; accountability failure.

CONTROL RESPONSE

Authoritative policy source; grounded responses; conformance testing; uncertainty threshold; human escalation; output monitoring.

THE GOVERNANCE QUESTION

Who owns the accuracy of an automated statement delivered through an official channel?

CASE 03

Air Canada Chatbot | Governance and regulatory response

Incorrect customer-facing policy information and organizational accountability

ISO/IEC 42001 ALIGNMENT

AI policy and objectives; accountability; information governance; impact assessment; monitoring; customer feedback and corrective action.

NIST AI RMF MAPPING

GOVERN: ownership and accountability
MAP: reliance and financial impact
MEASURE: accuracy and policy consistency
MANAGE: escalation, correction and redress

MANAGEMENT RECOMMENDATION

Treat chatbot outputs as official business representations, with named content owners and verifiable grounding.

Priority actions: accountable owner; defined system boundary; documented risk treatment; monitoring thresholds; evidence preservation; corrective-action closure.

EU AI ACT COMPARISON

Article 73 applies only if legally high-risk and the event meets the serious-incident definition. The case still illustrates deployer monitoring and accountability.

U.S. MARKET GAP

Existing law provided redress but did not impose a uniform preventive AI governance program.

CASE 04

Microsoft 365 Copilot EchoLeak | Incident anatomy

Indirect prompt injection and enterprise data-exfiltration risk

INCIDENT EVIDENCE

CVE-2025-32711 described AI command injection in Microsoft 365 Copilot that could allow unauthorized information disclosure over a network.

OBSERVABLE SYSTEM BEHAVIOUR

Could retrieve attacker-controlled email, process hidden instructions with trusted enterprise context and participate in an outbound exfiltration chain.

EXECUTIVE IMPLICATION

Treat enterprise copilots as privileged applications. Retrieved content is untrusted data, not authority.

RISK EXPOSURE

Prompt injection; cross-context leakage; excessive retrieval privilege; confidentiality breach; unsafe outbound rendering.

CONTROL RESPONSE

Context partitioning; provenance; least privilege; CSP; output filtering; AI DLP; block external fetches; adversarial testing.

THE GOVERNANCE QUESTION

Where must trust boundaries sit when untrusted content enters privileged enterprise context?

CASE 04

Microsoft 365 Copilot EchoLeak | Governance and regulatory response

Indirect prompt injection and enterprise data-exfiltration risk

ISO/IEC 42001 ALIGNMENT

Security and transparency objectives; data controls; interface management; operational monitoring; incident response and corrective action.

NIST AI RMF MAPPING

GOVERN: secure-AI policies
MAP: trust boundaries and data flows
MEASURE: injection and exfiltration tests
MANAGE: restrict, block and patch

MANAGEMENT RECOMMENDATION

Treat enterprise copilots as privileged applications. Retrieved content is untrusted data, not authority.

Priority actions: accountable owner; defined system boundary; documented risk treatment; monitoring thresholds; evidence preservation; corrective-action closure.

EU AI ACT COMPARISON

For in-scope systems, EU governance reinforces cybersecurity, post-market monitoring and incident reporting. Timelines are severity-dependent.

U.S. MARKET GAP

Security duties remain distributed across vulnerability, privacy, contract and sector regimes.

CASE 05

Uber Automated-Driving Test | Incident anatomy

Perception failure, disabled safety redundancy and fatal physical harm

INCIDENT EVIDENCE

The NTSB reported detection 5.6 seconds before impact, but no accurate classification or path prediction. Emergency braking was precluded by design.

OBSERVABLE SYSTEM BEHAVIOUR

Detected an object, changed classifications, failed to predict the path and continued without automated emergency braking.

EXECUTIVE IMPLICATION

Safety-critical AI must fail safely. Human oversight cannot substitute for engineered redundancy.

RISK EXPOSURE

Physical harm; unsafe uncertainty handling; disabled redundancy; inadequate fallback; insufficient scenario coverage.

CONTROL RESPONSE

Independent fail-safe braking; conservative defaults; sensor redundancy; safety case; operator monitoring; edge-case validation.

THE GOVERNANCE QUESTION

What independent safeguard intervenes when the primary AI system is uncertain or wrong?

CASE 05

Uber Automated-Driving Test | Governance and regulatory response

Perception failure, disabled safety redundancy and fatal physical harm

ISO/IEC 42001 ALIGNMENT

Impact assessment; safety objectives; competence and roles; operational risk controls; monitoring; incident investigation; improvement.

NIST AI RMF MAPPING

GOVERN: safety accountability
MAP: context and affected persons
MEASURE: night and edge-case tests
MANAGE: fail-safe response and stop-use criteria

MANAGEMENT RECOMMENDATION

Safety-critical AI must fail safely. Human oversight cannot substitute for engineered redundancy.

Priority actions: accountable owner; defined system boundary; documented risk treatment; monitoring thresholds; evidence preservation; corrective-action closure.

EU AI ACT COMPARISON

If legally high-risk, Article 73 gives a direct comparison: 10-day outer limit where death is involved, with immediate reporting once causality is established or suspected.

U.S. MARKET GAP

NTSB identified safety-culture and risk-management deficiencies, illustrating uneven testing governance.

CASE 06

Google Gemini Cyber Evaluation | Incident anatomy

Unintended internet access, scope ambiguity and access to real companies

INCIDENT EVIDENCE

Google confirmed Gemini accessed systems at three real companies during cyber tests. Reporting said internet access was unintended and a fictional target shared a real company name.

OBSERVABLE SYSTEM BEHAVIOUR

Guessed credentials in one case and used exposed credentials in two cases to access systems believed to be in scope; Google said the model stopped.

EXECUTIVE IMPLICATION

Bind test scope to verified infrastructure, not names. Require scope proof before consequential action.

RISK EXPOSURE

Target ambiguity; unauthorized access; isolation failure; credential misuse; third-party harm; disclosure inconsistency.

CONTROL RESPONSE

Synthetic domains; cryptographic target allow-list; no public DNS; default-deny egress; credential blocks; real-system tripwires.

THE GOVERNANCE QUESTION

How is target authorization verified before an agent takes consequential action?

Google Gemini Cyber Evaluation | Governance and regulatory response

Unintended internet access, scope ambiguity and access to real companies

ISO/IEC 42001 ALIGNMENT

AIMS boundaries; risk assessment; third-party relationships; evaluation controls; monitoring; incident communication and corrective action.

NIST AI RMF MAPPING

GOVERN: test accountability
MAP: real-world target ambiguity
MEASURE: scope and egress validation
MANAGE: stop, notify, preserve and redesign

MANAGEMENT RECOMMENDATION

Bind test scope to verified infrastructure, not names. Require scope proof before consequential action.

Priority actions: accountable owner; defined system boundary; documented risk treatment; monitoring thresholds; evidence preservation; corrective-action closure.

EU AI ACT COMPARISON

A serious-incident regime could standardize triage, reporting, investigation and corrective-action evidence; applicability depends on classification and harm.

U.S. MARKET GAP

No uniform agent-testing disclosure threshold across firms and sectors identified.